



Identity And Access Management



- I am Refers to **Framework or polices and technologies** for ensuring that the proper in an organisation have the Appropriate access to **Technology Resources**

or

Aws Identity and access Management is a web Services that help you Securely control Access to Aws Resources you use IAM to control who is authenticated(signed-in) Authorized (has Permission) to use Resources.

When you first create an **aws account** you begin with a single sign-in identity that Has **completely access to all aws services and resources in the account**

This identity is called the aws account “**root user**” and is accessed by **signing-in with the email Address and password** that you used to create the account

Aws strongly Recommended that you do not use the root user for your everyday task even the **Administrate ones**

Use Other **Iam Account** user account to manage the **administrative task** of your account and Securely lock away the root user Credentials and use them to perform only a few account and **Service Management Task**

IAM user limit is **5000 per** AWS account You Can add **upto 10 users at one at one time**

You are also limited to **300 groups per AWS Account**

Default Limits of Managed Policies attached to an iam Role **and IAM User is 10**

We can assign **two access keys (max) to an IAM User**

➤ Share Access to Your AWS Account

You can Grant other people **Permission to administer and use Resources** in your AWS Account without having to share your access Credentials (**Password or Access key**)

➤ GRANULAR PERMISSIONS

You can Grant different permission to different people for different Resources

For instance you can allow some users complete access to **ec2 s3 DynamoDB Redshift** while for others you can allow s3 buckets or permission to administer just some ec2 instance or to access your billing information but nothing else

➤ Secure Access to AWS Resources for Application that run Amazon ec2

you can use **IAM Features** to Securely give Applications that run EC2 instance the Credentials that they need in Other Aws Resources
Example **include S3 Buckets and RDS or DynamoDB database**

➤ Multifactor Authentication (MFA)

You can add two factor authentication to your account and to individual User for extra Security you can use Physical hardware or Virtual MFA (for Eg -> GOOGLE , Authenticator

➤ Identity Federation

You can allow users who already have passwords elsewhere for eg -> in your Corporate network or with an internet identity provider to get temporary to your AWS Accounts

➤ Identity information for assurance

If you use Aws CloudTrail you Receive log Records that include information are those who made request for resources on iam identities

➤ pci- DSS Compliance

IAM Support the processing steps and transmission of Credit Card by and merchant or Services Provider can have been Validated as Being Complaints with payment card Industries (pci) Data security Standard (DSS)

➤ Multifactor Authentication (MFA)

If a request to change some data is successful the change is committed and safely however the change must be replicated across iam which can take some time

Iam achieves high availability by Replicating data across multiple servers within Aws Data centre across the world

IAM Terms

- Principal
- Request
- Authentication
- Authorization
- Action/operation
- Resources

➤ Principal

A principal is a person or application that can make a request for an action or operation on AWS Resources

Your Administrate IAM user first principal

You can allow users and services to assume a Role

IAM User Roles Federated User application are all AWS Principal

You can support Federated Users or programmatic access to allow an application to Access your AWS Account

➤ Request

When a principal tries to use the aws management console the AWS API or the AWS CLI That principal sends a Request to AWS the request include the following information

➤ Action , Resources , Principal , Environment Data
Resources data

➤ Request => Action

Resources upon the actions are preformed

Principal information in environment from which the was made

Request Context

Before **Aws can Evaluate** and Authorized a **Request AWS gathers the Request information**

Principal (the Requester) which is determined based on the authorization data

This includes the aggregate permissions that the associated with that principal

Environment data such as **IP Addressm User agent SSL** enabled Status or the Time of day

Request data or data Related to Resources that is Beings Requested



Authentication

A principal Sending a Request must be authenticated (Signed in to AWS) to Send a Request to AWS

Some AWS Services like AWS S3 allow Request from anonymous Users they are exception to the Role

To Authenticate From the Console as a root user you must sign in with your user name and password

To authenticate from the api to CLI you must provide your access key and secret key

You might also be Required to Provide Additional Security Information like MFA (eg->

Google Authenticator)

➤ Authorization

To authorize Request , IAM Uses Value from the Request Context to check for matching Policies and determine wheatear to allow or deny the Request

IAM Policies are stored in IAM as JSON documents and Specify the permission that are allowed or Denied

User (Identity) based policies -> Specify permission allowed/Denied for principal

Note

By default only the AWS root user has access to all the Resources in that account

RESOURCE BASED POLICIES => Specify Permission Allowed/Denied for Resources
Popular for granting cross account Permission

IAM checks each policy that matches the context of your Request

If a single policy include a denied action iam denied entire Request and stop Evaluating
This is called Explicit Deny

The Evolution Logic Follows these Rules

- By default all request are denied
- An Explicit allow Overrides this Default
- An Explicit deny Override any allows

You can create a new IAM policy in the Aws management console using one of the following ways

Json -> you can create your own Json syntax

Visual Editor -> you can construct a new policy from scratch in the visual editor if you use the visual editor you do not have to understood Json syntax

Import -> you can import a managed policy within your and then edit the policy to customized it to your specific Requirements

➤ Actions

Action are defined by a Service and are the things that you can do to a such as viewing creating editing delating that Resource

Iam supports approx. 40 accounts a user Resource including create user delete user

Any actions or Request that are not explicitly allowed are denied by default

After your request has been authenticated and authorized AWS the actions in your Request

➤ Resources

A Resource is an entity that exist within a server

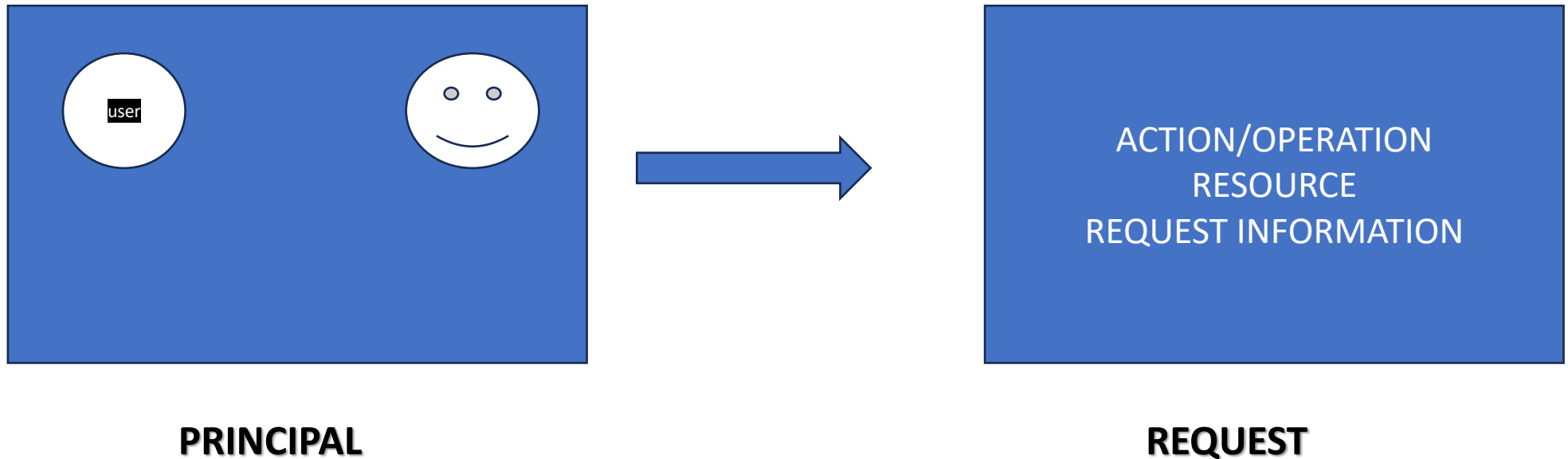
Example are Ec2 instance s3 buckets iam users DynamoDB table

Each aws Service define a set of actions that can be performed on each Resource

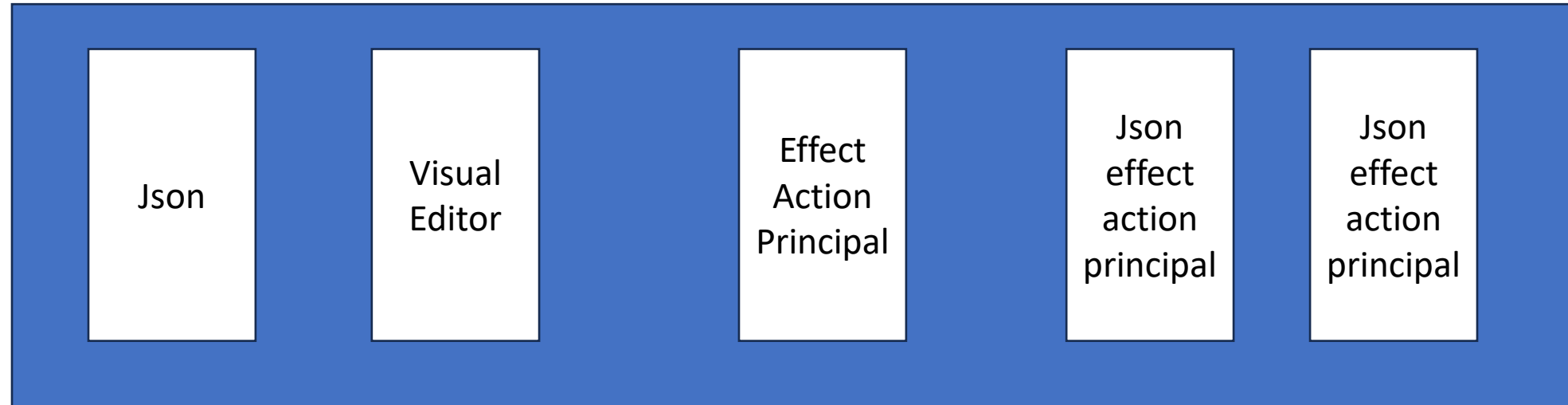
After aws approve the actions in your Request those actions can be performed on the related resource within your accounts

If you create a request to perform an unrelated action on a Resources that Request is derived

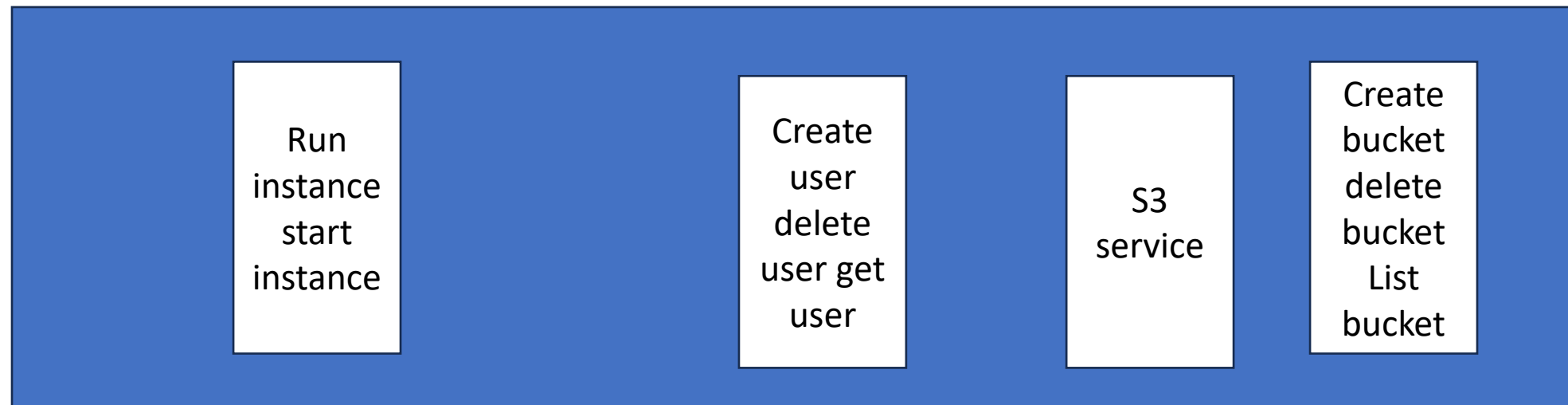
When you provide permission using an identity based policy in iam then you provide permission to access resources only within the accounts



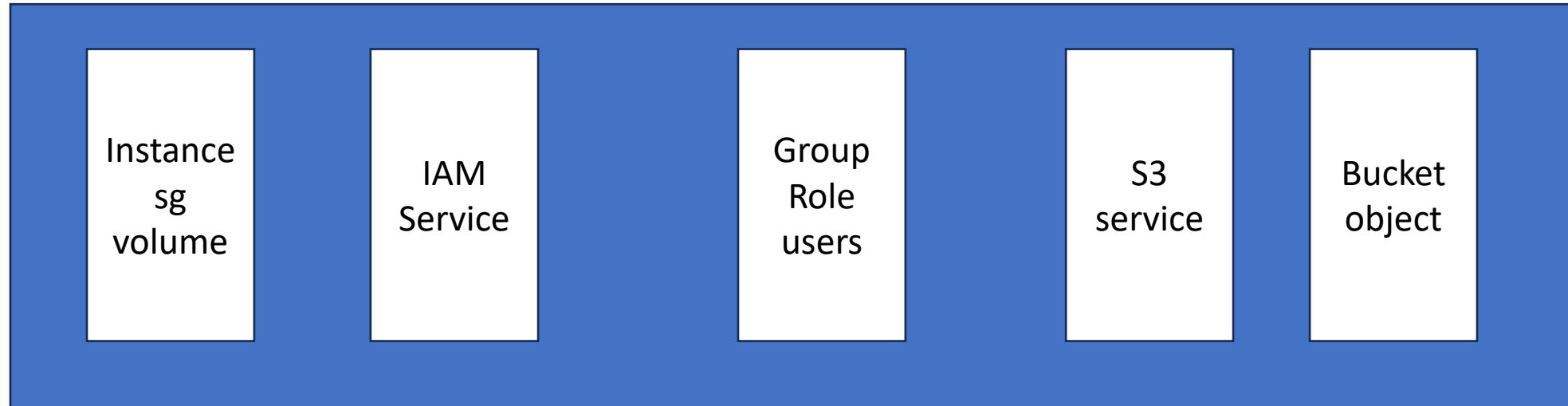
Authorizations



Actions (console) or Operation(Api /CLI)



Resources



➤ Identity Federation

If your account users already have a way to be authenticated such as authentication through your corporate network

You can federate those user identities into AWS

A user who has already logged to the corporate using their corporate identity

The corporate can replace their existing identity with a temporary identity in your AWS account

The user can work in the AWS Management Console

Similarly an application that the user is working with can make programmatic request using permission that you define

Federation is particularly useful in those case :-

Your user already have identities in a corporate directory

if your corporate directory is compabble with Security Assertion Markup Language(2.0)

If you can configure your corporate directory to provide single sign-on (sso) access to the Aws Management console for your users

If your corporate directory is not compatible with saml 2.0

You can create identity broker application to provider single sign-on(sso) access to the aws management console for your users

If your corporate directory is Microsoft active directory you can use AWS Directory service to establish trust between corporate directory and your aws account

your user already have internet identities :-

If you are creating a mobile app or web based app that can let user identity themselves through an internet identity provider link login with amazon facebook google or any open id Connect (oidc) compatible identity provider that app can use web federation to access aws

AWS Recommends to use aws Cognito for Identity Federation



IAM Identities

- **User**
- **Groups**
- **Role**

IAM Identities is what you create under your aws account to provide authentication for people application and process is your aws account

Identities Represent the user and can be authenticated and then authorized to perform action in aws

Each of these can be associated with one or more policies to determine what action a user role or member of a group can do with which resource and under what condition

IAM group is a collection of IAM User

IAM role is very similar to IAM User

➤ IAM USERS

AN IAM user is an entity that you create in aws it represent the person or service who use the iam user to internet with aws

You can create 5 user at a time

An IAM user can Represent an actual person or an application that requies aws access to Perform actions on aws Resources

A primary use for IAM user is to give people the ability to sign-in to the aws management console for interaction task and to make programmatic request to aws service using the api CLI

➤ **IAM GROUPS**

An IAM group is collection of IAM user

It IS A ways to assign permission/ policies to multiple user at once

Uses groups to specify permission for a collection of user which can make those permission easier to manage for those users

For example :- you could have a group called HR and give that group type of permission that HR Department Typically needs

Any user in that group Automatically has the permission that assigned to the group

If a new user joins yours oraganisation and should have administrator priviledges you can assign the permission by adding the user to that accounts

If a person changes job your organization instead of editing that users permission you can remove him or her from the old groups and add him or to the appropriate new groups

IAM GROUPS LIMITATIONS

A Group is not truly an identity IAM Because It can't identified as a principal Is a permission policy

Groups can't be nested

You have a limits of 300 groups in an AWS account

A user can be a member of up to 10IAM groups



IAM ROLES

An IAM role is very similar to a user in that it is identity with permission policies that determine what the identity can and can't do AWS

An IAM role doesn't not have any Credentials (password or access keys) associate with it

Instead of being uniquely associated with one person a role is intended to be assumed by anyone who needs it

An IAM user can assume a role temporarily to take on different permissions for a specific task

An IAM role can be assigned to a federated user sign-in by using an external identity provider of IAM

➤ **IAM TEMPORARY CREDENTIALS**

Temporary Credentials are primarily used with IAM roles but there are also uses

you can Request credentials that have a more Restricted set of permissions than your standard IAM user

This Prevents you from Accidentally performing tasks that are not permitted by the more Restricted Credential

A benefit of temporary Credentials is that they Expire Automatically after a set period of time

➤ PERMISSION AND POLICIES

The access management portion of aws identity and access management (IAM) helps you to defined what a user or other entity is allowed to do in a account referred to as authorization

Permission are granted through person that are created and then attached to user groups or roles

➤ POLICIES AND USERS

By Default IAM users can't access anything in your accounts

You grant permission to user by creating a policy which a document that defined the effect action resource and optional condition

Any actions or Resources that are not explicitly allowed are derived by default

➤ IAM Multiple Policies

User or Groups can have multiple policies attached to that grant different permission

In the case of multiple policies attached to a user (or groups)

The users permission are calculated based on the combination of policies

➤ FEDERATED USERS AND ROLES

Federated user don't have permanent identities in your aws accounts the way that iam users do

To assign permission to federated users you can create an entity referred to as a role and define permission for the Role

When a federated user signs in to aws the user is associated with the role and is granted the permission that are defined in the role

➤ Resources Based Policies

IN same case (like s3 Bucket) you can attached a policy to a resource in addition to attaching it to group or user this is called a resources Based Policy

A Resource based Policy contain slightly different information than a user policy

In a Resources based Policy you specific what actions are permitted and what resources are Different

You also explicitly list who is allowed access to the Resources a (principal)

Resources based policies include a principal elements that specifies who is granted the permission

➤ Inline policy

We have many options to give the permission to the principal users

Ec2Full Access

Ec2Readonly

Ec2 volume

Image copy and many more permission we give to the principal

➤ IAM Users the Roots Users

When you first create an AWS account you create an account's (or root user's) identity which you use to sign-in to AWS.

The account's root user credentials are the email address used to create the account and password which can be used to sign-in to the AWS management console as the root user.

When you sign-in as the root user you have complete unrestricted access to all resources in your AWS account including access to your billing information and the ability to change your password.

The level of access is necessary when you initially set up the account.

It is not possible to restrict the permissions that are granted to the AWS account.



AWS Recommends that

Aws recommends that you don't use root user credential for everyday access

Also aws recommends that you don't share your root user credential with anyone because doing so gives them unrestricted access to your accounts

Create an iam user for yourself and then assign yourself administrative permission for your accounts

You can then sign-in as that user to add more user as needed

An iam user with administrator permission is not the same things as the aws accounts
Root users



IAM USERS

AN IAM user is an entity that you create as it represents the person or service who uses AWS. It represents the person or service who uses the IAM user to interact with AWS.

An IAM user can represent an actual person or an application that requires AWS access to perform actions on AWS resources.

IAM users are global entities like an AWS account; they are not region-specific. A user's permissions apply to AWS services in any geographic region.

For any user you can assign them

A username and password to access the AWS console.

An access key (access key ID and secret key) that they can use for programmatic access (issuing requests) to your AWS service using API and CLI.

You assign either or both based on activities and needs

You can view and download your secret access key only when you create the access key

You can't view or recover a secret access key later

if you view or Recover or regenerate access key later

If you lose your secret access key you can create a new access key